

LEY MARCO DE CIBERSEGURIDAD N°21.663

Plan de Tratamiento de Riesgos de Ciberseguridad

Normativa	Ley Marco de Ciberseguridad N°21.663
Organización	Laboratorio Clínico ACLIN Ltda.
Responsable de Ciberseguridad	Paulina Tapia Hernández (CISO)
Versión del documento	1.0
Período de cumplimiento	Octubre 2025 – Octubre 2026
Fecha de emisión	15 / 03 / 2026

Clasificación: Confidencial — Jaime Gómez Ayala — Auditor Externo de Ciberseguridad

1. OBJETIVO

Definir las acciones, controles y responsables necesarios para reducir, gestionar o eliminar los riesgos de ciberseguridad identificados en la Matriz de Riesgos del Laboratorio Clínico ACLIN Ltda..

2. ALCANCE

Este plan aplica a todos los activos críticos de la organización incluyendo sistemas de información, bases de datos de pacientes, infraestructura tecnológica, redes y servicios digitales que soportan las operaciones del laboratorio.

3. ESTRATEGIAS DE TRATAMIENTO

- Mitigación: implementar controles de seguridad que reduzcan la probabilidad o impacto del riesgo.
- Transferencia: transferir el riesgo a terceros mediante seguros o contratos.
- Aceptación: aceptar el riesgo cuando el impacto es bajo y el costo de mitigación es mayor.
- Eliminación: eliminar el riesgo eliminando el activo o proceso vulnerable.

4. RIESGOS CRÍTICOS — ACCIÓN URGENTE REQUERIDA

Los siguientes riesgos tienen nivel **CRÍTICO** ($P \times I \geq 17$) y requieren intervención inmediata conforme a la Ley 21.663.

Riesgo	Medidas de tratamiento	Responsable	Prioridad	Estado
IDOR pacientes.aclin.cl (~21.000 exámenes expuestos)	Validación autorización por sesión, reCAPTCHA, auditoría accesos, revisión todos los endpoints similares	Desarrollo / TI	CRÍTICA (25)	Pendiente implementación

MSSQL puerto 1122 expuesto a Internet	Cerrar puerto 1122 externamente, FW perimetral, acceso solo desde red interna, monitoreo intentos conexión	TI Infraestructura	CRÍTICA (20)	Pendiente implementación
HTTP sin cifrado en pacientes.aclin.cl	SSL/TLS válido, forzar HTTP→HTTPS, HSTS, actualizar todas las URLs internas	TI Infraestructura	CRÍTICA (20)	Pendiente implementación

5. RIESGOS ALTOS Y MEDIOS

Riesgo	Medidas de tratamiento	Responsable	Prioridad	Estado
Ransomware en servidor LIS	EDR, segmentación de red y backups offline	Área TI	Alta	En planificación
Filtración datos de pacientes	Cifrado de BD y MFA	CISO / TI	Alta	Pendiente MFA
Phishing correo institucional	Capacitación usuarios y filtros antiphishing	Área TI	Media	En progreso
Acceso no autorizado red interna	Monitoreo accesos y segmentación	TI Infraestructura	Media	En planificación
Falla sistema de respaldo	Pruebas trimestrales de restauración	Área TI	Alta	Parcialmente implementado
Headers HTTP faltantes (IIS)	Config. Referrer-Policy, X-Frame, CSP, HSTS, X-XSS	TI Infraestructura	Media	Pendiente

6. RESPONSABLES

Nota: El Auditor Externo supervisa el tratamiento de riesgos de forma independiente. La implementación técnica de controles es responsabilidad del CISO y el Área TI.

Jaime Gómez Ayala – Auditor Externo: supervisión independiente del tratamiento de riesgos.

Paulina Tapia Hernández – CISO: coordinación y validación de controles implementados.

Área de TI: implementación técnica de controles.

Comité de Ciberseguridad: revisión periódica del estado de los riesgos.

Dirección: aprobación de decisiones estratégicas.

7. SEGUIMIENTO Y CONTROL

El estado de los riesgos y la implementación de controles será revisado trimestralmente por el Comité de Ciberseguridad. Los avances deberán registrarse como evidencia para auditorías de cumplimiento de la Ley Marco de Ciberseguridad N°21.663.

8. REVISIÓN DEL PLAN

Este plan será revisado al menos una vez al año o cuando se identifiquen nuevos riesgos relevantes derivados de cambios tecnológicos, auditorías o incidentes de seguridad.

9. APROBACIÓN · VIÑA DEL MAR, CHILE

Representante Legal / CEO – ACLIN Ltda.

Marcelo Tapia Carrere

Firma

Auditor Externo · RUT 16.302.178-1

Jaime Gómez Ayala

Firma

Fecha de aprobación: ____ / ____ / 2026